

Safe AI Automation for MSP Operations — One-Page Briefing

Concept: The Trust Ladder · Munshi Javed Akhtar · Illustrating workflow: *Ransomware* → *Isolate & Restore* — a high-stakes case needing both cyber protection and backup, driven by two agents: a **Triage Agent** (confirm the threat, find a clean backup) handing off to a **Remediation Agent** (isolate + restore).

The bet: workflow **builders** define *what* an agent does. They don't answer the question that actually blocks adoption — **would an MSP dare turn a destructive agent loose on a client's production estate, and can they defend it afterwards?** This project designs the **trust-and-control layer** around the canvas that lets an MSP take an agent from **off** → **autonomous, one earned rung at a time, with the right person in control at each step.**

The design problem

The real bottleneck is "confidence, oversight, accountability... trust, reliability." None of that lives in the canvas; it lives around it. An MSP won't flip a destructive agent to "autonomous" on day one: their client's uptime and their own liability are on the line. So **trust has to be earned, measured, reversible — and correctly permissioned.** Building another builder would have re-shown solved ground; the harder, unsolved problem is **trust and control.**

Five surfaces in the prototype

- Safe activation (5 steps):** Scope (a hard containment boundary) → **guardrails enforced by the platform, not the model** — with a live **script linter** (inject `Remove-Item`, watch it get blocked) → **dry-run over 90 days of the tenant's real incidents** (proof, not promises — it surfaces a genuine divergence and proposes a new guardrail) → **autonomy rung** (Shadow → Suggest → Approve-to-act → Auto+notify) → **canary** with auto-pause.
- Oversight inbox:** human-in-the-loop *without* the human as bottleneck — every item shows the agent's **reasoning, evidence, calibrated confidence, and per-guardrail checks**, so approval takes seconds and each rejection becomes training signal. A low-confidence *domain-controller* case shows the agent correctly *escalating instead of acting*; the Triage Agent shows it choosing *not* to hand a destructive action downstream.
- Execution & audit trail:** a tamper-evident, exportable record — *what did it do, why, on whose authority, can we undo it* — showing the **Triage → Remediation hand-off** and **one-click rollback** (every action is a reversible transaction with a pre-action snapshot).
- Reliability & evals:** trust as a *continuous* measure — human-agreement trend vs a 95% promote threshold, drift alerts, and an eval suite (golden set, destructive-action safety, prompt-injection). **The loop closes:** inbox rejections & dry-run divergences return as new labelled cases.
- Role-based control (RBAC) — who may do what:** a role switcher (Owner · Admin · Technician · Auditor) visibly re-skins the UI. The **kill switch is tiered** (Owner/Admin pause the fleet; a Technician pauses one agent); **€-ROI shows to Owner/Admin but is replaced by an accuracy view for Technicians**, so front-line reviewers are never pressured to rubber-stamp for savings. Separation of duties as a product surface, not a settings page.

Key trade-offs

- Platform-enforced, not prompt-enforced** — a mis-reasoning model is still *physically* stopped from isolating a domain controller, restoring an unverified backup, or running a destructive command. The model proposes; the platform disposes.
- Autonomy is a dial, not a switch** — trust rises with evidence, falls on drift; the human checkpoint sits between classification and any destructive action — multi-agent orchestration made auditable.
- Reversibility is the price of automation** — destructive actions ship only when they're undoable; irreversibility is what makes teams refuse to activate at all.
- Who-can-do-what is a safety control** — showing € to the wrong role, or a global kill switch to every junior, are both failure modes. RBAC is designed in, not bolted on.
- Deliberately out of scope (next):** two-person approval quorum for the highest-risk actions; cross-workflow blast-radius budgets.

How it was built — fast, cheaply, and with judgment

Primary tool: Claude (Anthropic), run as a prototyping harness — not a chatbot. The aim was to **validate a concept end-to-end before any engineering is committed**, and do it fast and cost-consciously.

- Product judgment drove every decision.** Claude was used to *pressure-test*, never to decide — including arguing against the framing ("why would an MSP actually distrust this?"). Its first cut was a single all-powerful user; that was rejected as unsafe for a *safety* product and directed into the RBAC redesign. The concept is human; the AI compressed the build.
- Work split across focused agents.** One stream scoped the problem, one generated the prototype, one adversarially reviewed it for stale references and inconsistencies, one produced the PRD and architecture docs — so streams ran in parallel instead of one long thread. A review pass caught four stale workflow references that would otherwise have shipped.
- Cost managed deliberately.** Models were **tiered** — a smaller, cheaper model for mechanical scaffolding, boilerplate, and formatting; the top model reserved for the reasoning that mattered (the trust model, the RBAC rationale, the failure-mode analysis). Tight, spec-first prompts and reused context kept token spend low.
- Speed with an artifact to show for it.** A clickable, dependency-free single-file prototype (no build step, opens in any browser), a one-page briefing, a full PRD, and a backend architecture doc — a working thing to react to, which is the entire point of prototyping before engineering invests.

Run it: open `prototype/index.html`. Read the **"what the agent does / why it beats a human at 3am"** panel on **Activate agent** → use the **"Viewing as"** switcher (top bar) to compare **Admin vs Technician vs Auditor** (ROI, kill switch & buttons change) → step through **Activate agent** (run the dry-run; inject a forbidden command & re-check) → **Oversight inbox** (the domain-controller block, and the Triage Agent choosing *not* to escalate) → **Execution & audit** (the Triage → Remediation hand-off) → **Reliability & evals**. *Companion doc: full PRD.*